SECURITY ENGINEERING PORTFOLIO

Yosef Moshe: firewalls, identity and SIEM, built and broken at home

IT Specialist with about ten years across IT infrastructure, IAM, ISO 27001 compliance and SOC Tier 2 operations. These two projects show how I design a segmented network, run Active Directory on Linux, feed everything into Wazuh, and automate blocking from threat intelligence.

pfSense · Suricata · pfBlockerNG · Samba AD · Wazuh · FortiGate · T-Pot honeypot · AWS · Python · Docker · AbuseIPDB API

PROJECT 1 · 2025

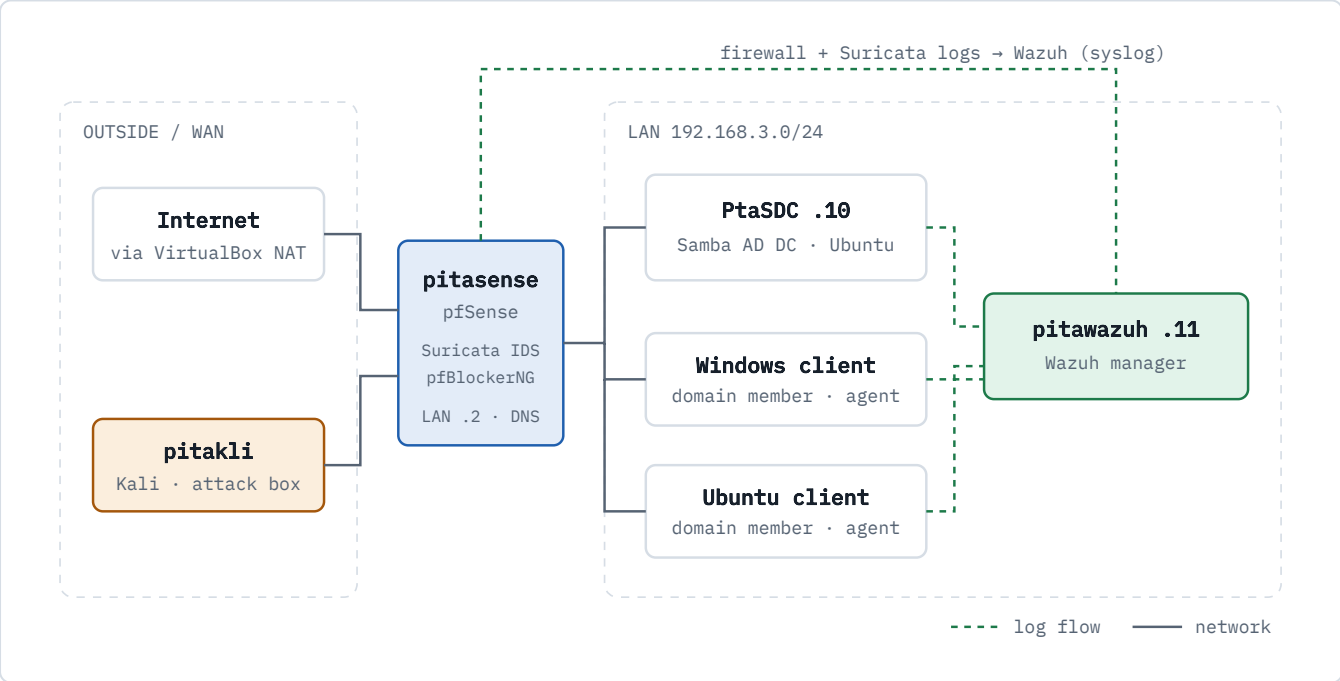
pitaworld: a segmented AD domain monitored end to end

Five VirtualBox machines on one always-on desktop. pfSense sits between the outside and a /24 lab LAN. A Samba domain controller and the Wazuh server live on that LAN, and every host and the firewall report to Wazuh.

Domain **pitaworld.pita** LAN **192.168.3.0/24** DHCP **.13–.245** Hypervisor **VirtualBox**

ARCHITECTURE

Network topology



FIREWALL POLICY

LAN rules: allow only what the domain needs

Taken from the pfSense configuration backup. Blocklists are evaluated first, then each allowed service is opened to a specific host and port. Every rule logs, so Wazuh sees both allowed and denied traffic.

ACTION	SOURCE	DESTINATION	PURPOSE
REJECT	LAN	pfB_PRI1_v4	pfBlockerNG threat-intel list
BLOCK	blocklist	any	Known-bad sources, both directions
PASS	LAN	.2 : 53	DNS for the domain
PASS	LAN	.10 : 88	Kerberos authentication
PASS	LAN	.10 : 389–636	LDAP / LDAPS
PASS	LAN	.10 : 445	SMB for GPOs and file shares
PASS	LAN	.10 : 135–139	RPC / NetBIOS
PASS	LAN	LAN : 1510–1515	Wazuh agent enrollment and events
PASS	LAN	LAN : 55000	Wazuh API
PASS	LAN	any : web_access	Outbound web only

SIEM CONFIGURATION

What the Wazuh manager is set up to do

Firewall log intake

A syslog listener on `514/tcp` accepts only the lab subnet, so pfSense and Suricata events land next to endpoint data.

Automatic containment

Active response runs `firewall-drop` and `host-deny` for 60 seconds when custom rule `100100` fires.

File integrity

Monitors `/etc`, `/usr/bin`, `/usr/sbin`, `/bin`, `/sbin` and `/boot`, and alerts on new files.

Posture and vulnerabilities

SCA benchmark scans every 12 hours, vulnerability detection with hourly feed updates, and hourly asset inventory.

Full archives

All events are archived as JSON, not just alerts, so I can hunt back through raw logs after an attack.

Threat lists

Loads the AlienVault blacklist and Windows security event channel CDB lists alongside the default ruleset.

```
<!-- ossec.conf excerpt: contain the source for 60s when rule 100100 fires -->
<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>100100</rules_id>
  <timeout>60</timeout>
</active-response>
```

PROJECT 2 · 2024

Honeypot to firewall: an automated IP reputation blocklist

A honeypot on AWS collects attacker IPs. A Python script checks each one against AbuseIPDB, confirmed IPs are published as a feed, and FortiGate pulls that feed into a deny policy in front of the lab LAN.

PIPELINE

STAGE 1
Capture

T-Pot honeypot on AWS logs every inbound attacker.

STAGE 2
Verify

Python checks each IP against the AbuseIPDB API and keeps high-confidence ones.

STAGE 3
Publish

A Docker container serves `malicious_ips.txt` over HTTP.

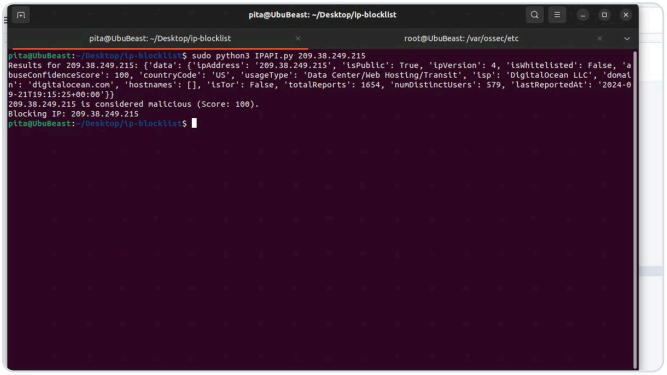
STAGE 4
Block

FortiGate external threat feed `malicious_ips` feeds a DENY policy, WAN to PitaLAN.

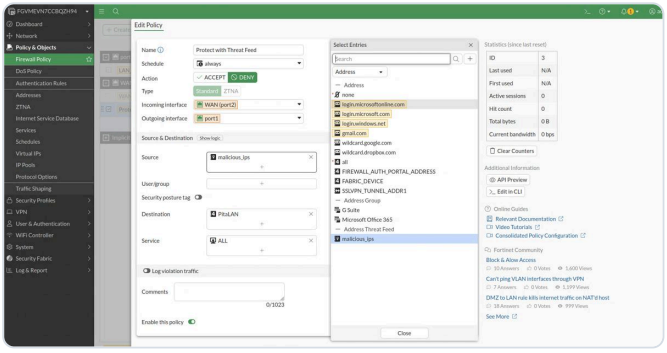
STAGE 5
Alert

Wazuh custom rule `100200` flags hits from honeypot IPs.

EVIDENCE



The reputation script flags a DigitalOcean IP with an AbuseIPDB confidence score of 100 and 1,654 reports, then blocks it.



FortiGate policy "Protect with Threat Feed" denies any traffic from the feed into the lab LAN.

```
# Dockerfile: serve the verified blocklist to FortiGate
FROM python:3.9-slim
WORKDIR /app
COPY malicious_ips.txt /app/malicious_ips.txt
EXPOSE 8080
CMD ["python", "-m", "http.server", "8080"]
```

NEXT ITERATION

What I would change next

- Put the Kali box on its own pfSense interface, so every simulated attack crosses a logged firewall rule before it reaches the domain.
- Move the LAN from a host-only adapter to an internal network, so the physical host is not part of the lab.
- Run the reputation script through Wazuh active response in `ossec.conf`, so detection and blocking happen in one place.
- Turn on violation logging in the FortiGate deny policy, so blocked attempts show up in Wazuh as evidence.